

Phishing Attack Investigation

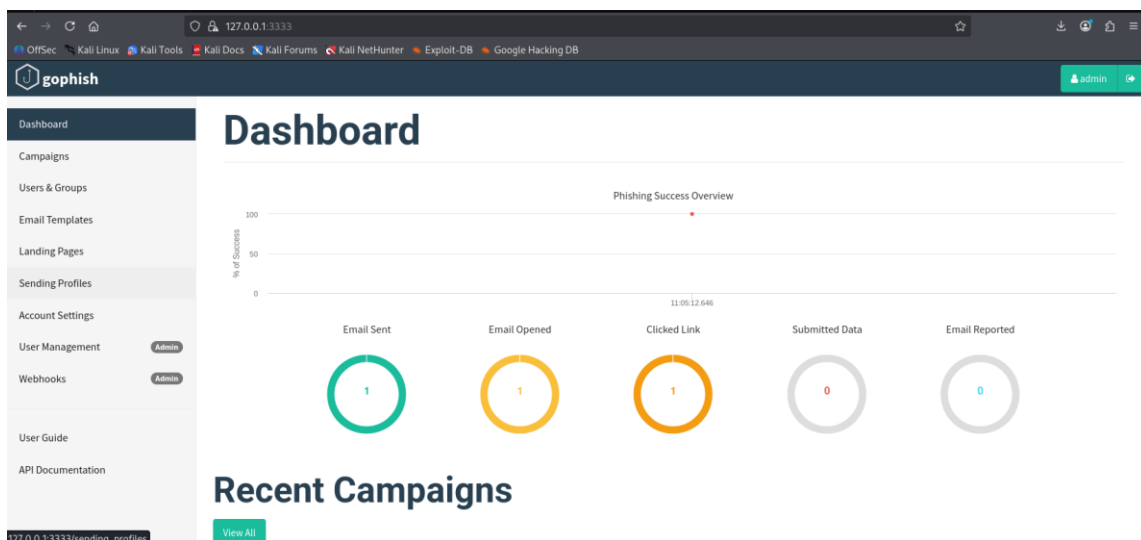
1. Giới thiệu về Phishing Attack.

Phishing attack là: Tấn công lừa đảo (phishing) là một mối đe dọa an ninh mạng phổ biến, trong đó kẻ tấn công lừa gạt các cá nhân cung cấp thông tin nhạy cảm bằng cách giả mạo là một tổ chức đáng tin cậy. Dự án này nhằm tìm hiểu và vận dụng các kỹ năng để nhận diện, điều tra và ứng phó hiệu quả với các cuộc tấn công lừa đảo.

2. Mô phỏng 1 cuộc tấn công Phishing Email.

Sử dụng công cụ GoPhish để giả lập 1 cuộc tấn công Phishing Email nhằm thu thập các thông tin nhạy cảm (tài khoản và mật khẩu) của người dùng.

Bước 1: Truy cập giao diện của công cụ GoPhish



Bước 2: Để gửi email, Gophish yêu cầu cấu hình chi tiết chuyển tiếp SMTP được gọi là “Sending Profiles” với:

- Name: Là tên profile.
- Interface type: Giao thức sử dụng để gửi email (Mặc định là SMTP).
- SMTP From: Địa chỉ email và tên hiển thị của người gửi mà nạn nhân sẽ nhìn thấy trong hộp thư đến.
- Host: Địa chỉ IP kèm theo cổng (port) của máy chủ SMTP dùng để phát tán email, ở đây ta sử dụng địa chỉ IP của mailcatcher.

Edit Sending Profile

×

Name:

TestPhishing

Interface Type:

SMTP

SMTP From: ?

Anhxyz<Support@google.com>

Host:

172.16.1.134:1025

Username:

Username

Password:

☒ Ignore Certificate Errors ?

Email Headers:

Bước 3: Tạo Email Template, là nội dung của các email được gửi đến người nhận. Để tạo Email, trước tiên hãy truy cập trang “Email template” và nhấp vào nút “New template”.

New Template

Name:

[Import Email](#)

Envelope Sender:

Subject:

Text **HTML**

File "Invoice Information.xlsx" Shared with You

Hello Phg Nguyen,

Nhập email: Chuẩn bị một mẫu email giả mạo để nhập.

Import Email

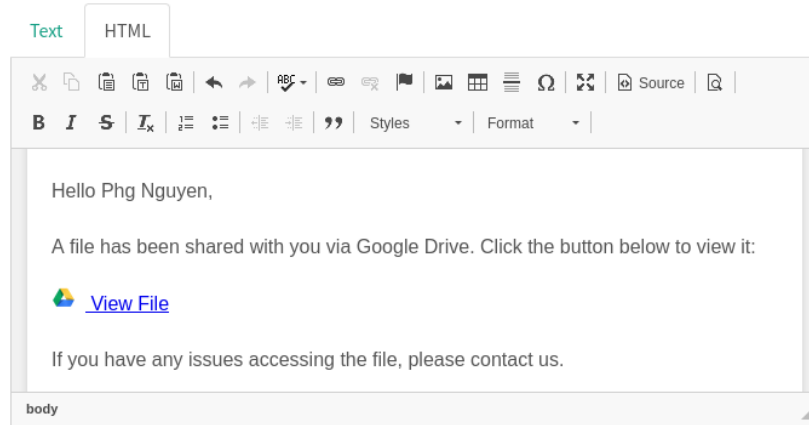
Email Content:

```
Mime-Version: 1.0
Date: Tue, 28 Jul 2026 11:05:12 -0400
X-Mailer: gophish
Message-Id: <1785251112660790926.11634.6576417821464558106@kali>
Subject: Microsoft Security Alert
To: "phg nguyen" <phgnguyenxyz@gmail.com>
From: Support@google.com
Content-Type: text/html; charset=UTF-8
Content-Transfer-Encoding: quoted-printable
```

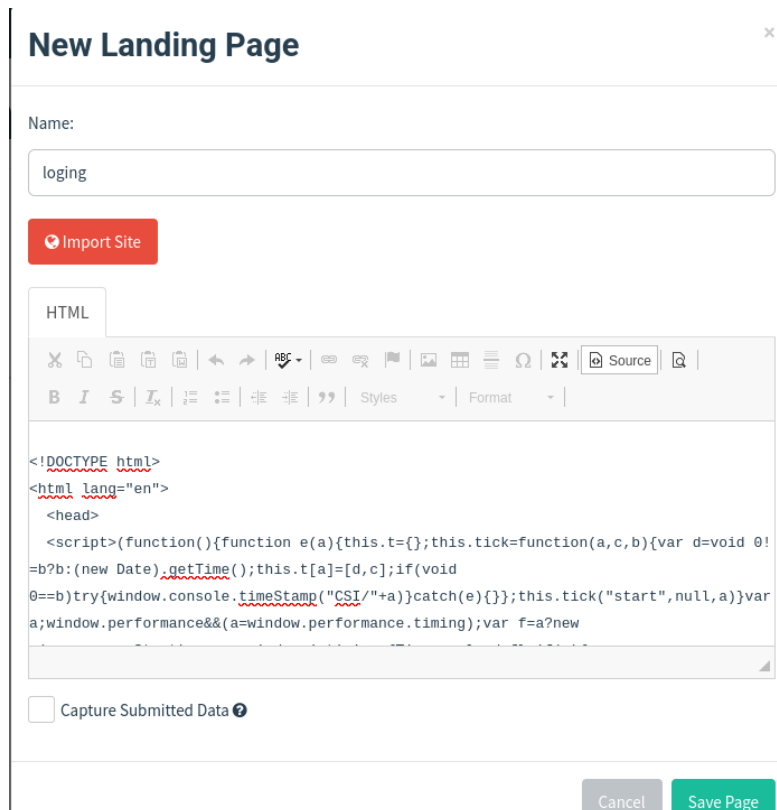
☒ Change Links to Point to Landing Page

[Cancel](#) [Import](#)

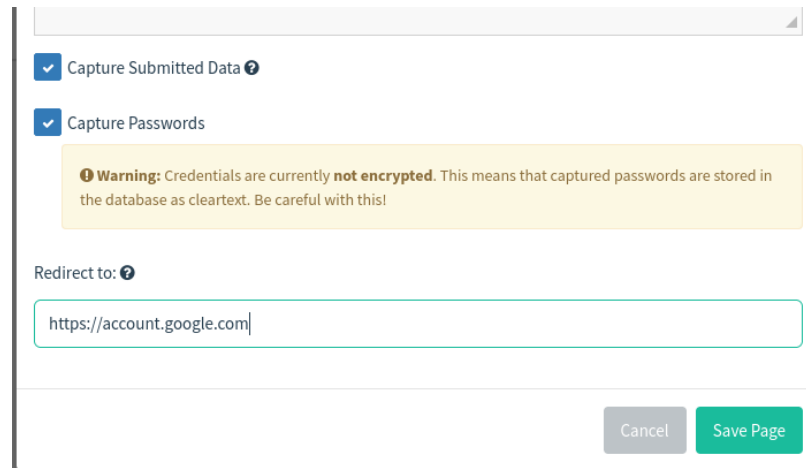
Trình chỉnh sửa HTML: chuyển đổi giữa mã nguồn HTML và chế độ xem trực quan.



Bước 4: Tạo Landing Pages là các trang HTML thực tế được trả về cho người dùng khi họ nhấp vào các liên kết lừa đảo mà họ nhận được. Landing Pages hỗ trợ tạo mẫu, thu thập thông tin đăng nhập và chuyển hướng người dùng đến một trang web khác sau khi họ nhập thông tin đăng nhập.

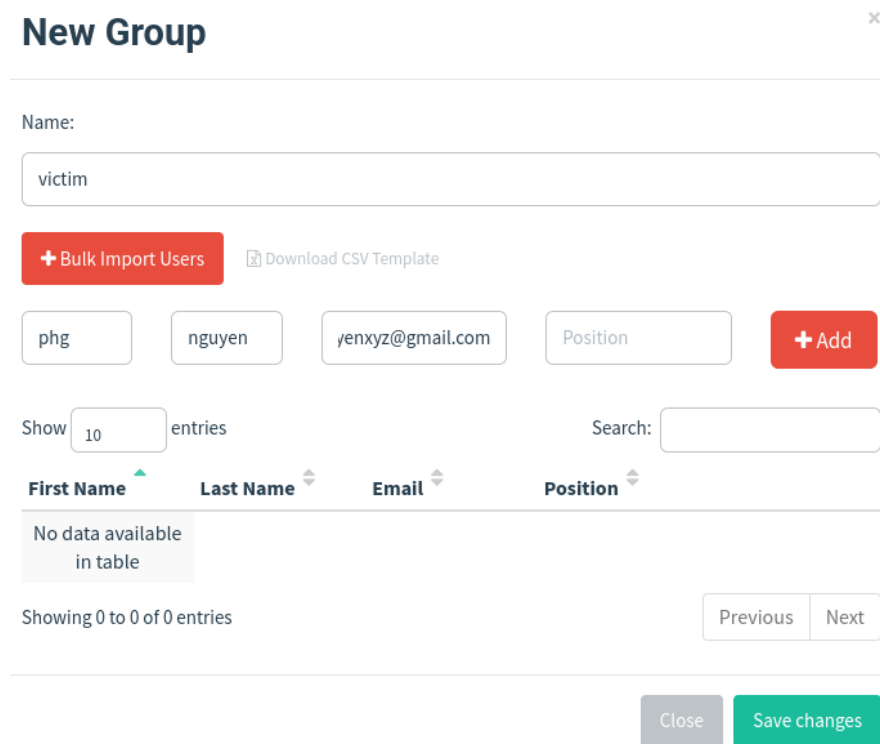


Chuẩn bị sẵn landing pages giả để nhập vào phần HTML và tích vào ô Capture Submitted Data , ô Capture Passwords để có thể chuyển hướng người dùng từ trang web giả mạo tới trang web thật để đánh lừa người dùng



The screenshot shows a configuration panel for capturing web data. At the top is a dropdown menu. Below it are two checked checkboxes: "Capture Submitted Data" and "Capture Passwords". A yellow warning box states: "Warning: Credentials are currently not encrypted. This means that captured passwords are stored in the database as cleartext. Be careful with this!". Below the warning is a "Redirect to:" label and a text input field containing "https://account.google.com". At the bottom right are "Cancel" and "Save Page" buttons.

Bước 5: Tạo User & Group quản lý các nhóm người dùng được nhắm mục tiêu tới



The screenshot shows the "New Group" interface. At the top is the title "New Group" with a close button. Below is a "Name:" label and a text input field containing "victim". There are two buttons: "+ Bulk Import Users" and "Download CSV Template". Below these are four input fields: "phg", "nguyen", "yenxyz@gmail.com", and "Position", followed by a red "+ Add" button. Below the inputs is a "Show 10 entries" control and a "Search:" input field. A table header shows "First Name", "Last Name", "Email", and "Position", each with a sort arrow. The table body contains the message "No data available in table". At the bottom left is "Showing 0 to 0 of 0 entries". At the bottom right are "Previous" and "Next" buttons. At the very bottom are "Close" and "Save changes" buttons.

Có thể thêm người dùng vào nhóm theo hai cách:

- Thêm người dùng theo cách thủ công, hãy điền thông tin vào các ô văn bản "Tên", "Họ", "Email" và "Position" rồi nhấp vào nút "add".
- Tải lên hàng loạt người dùng từ tệp CSV.

Bước 6: Tạo Campaigns để triển khai các chiến dịch. Điều này bao gồm việc gửi email đến một hoặc nhiều nhóm và theo dõi xem email đã được mở, liên kết đã được nhấp hoặc thông tin đăng nhập đã được gửi hay chưa.

New Campaign

Name:

Email Template:

Landing Page:

URL:

Launch Date: Send Emails By (Optional):

Sending Profile:

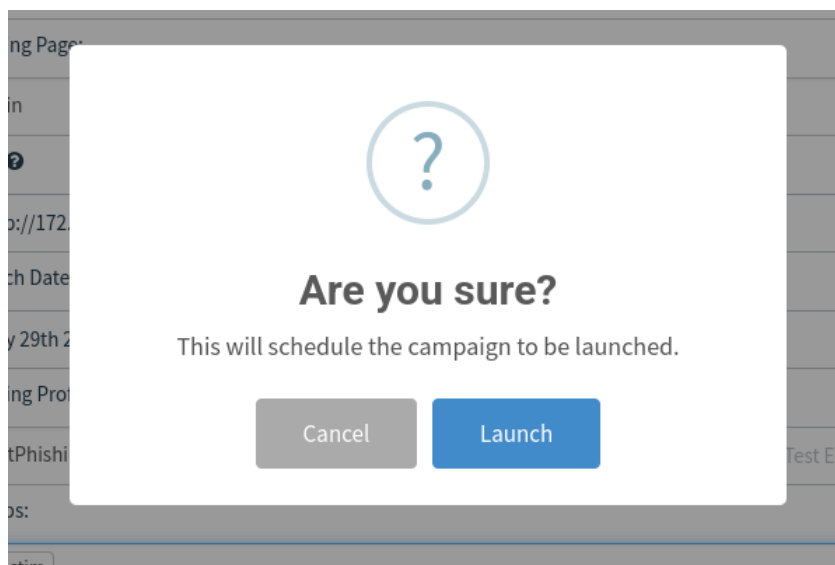
Groups:

Để thiết lập Campaigns, cần cung cấp các thông tin sau:

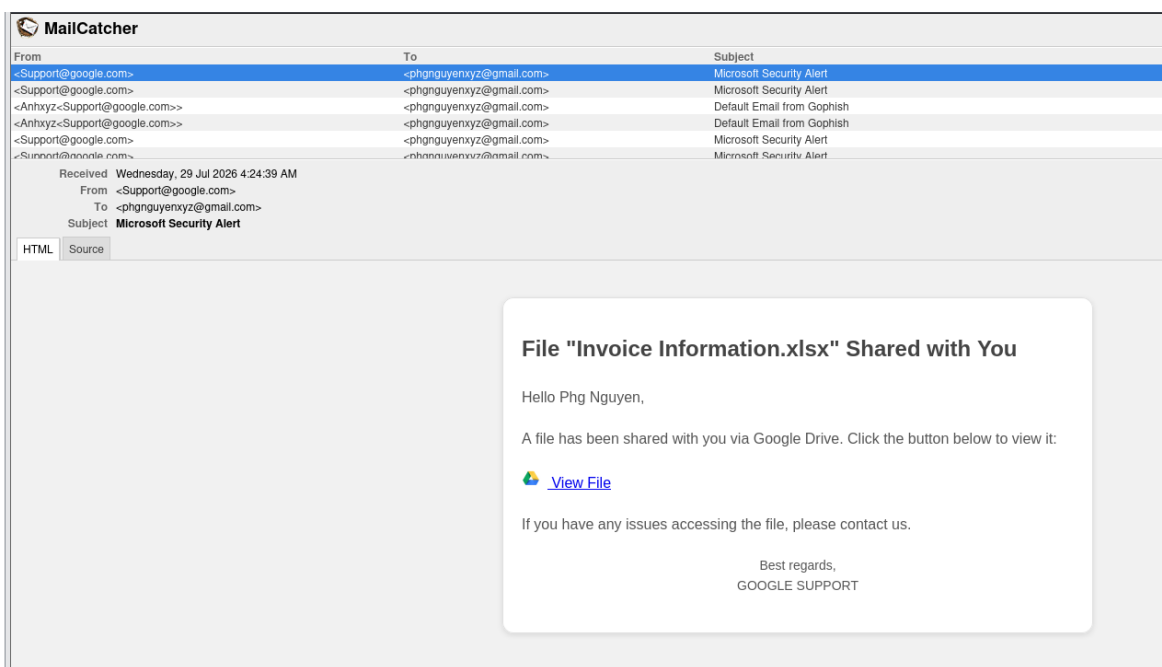
- Name: Tên của chiến dịch
- Email templates: Email được gửi đến người nhận trong chiến dịch. Mẫu này được tạo trong phần Mẫu email của tài liệu hướng dẫn.
- Landing Pages: Mã HTML được trả về khi người nhận nhấp vào liên kết trong mẫu email. Mã này được tạo trong phần Trang đích của tài liệu hướng dẫn.
- URL: Đây là URL dùng để điền {{.URL}} giá trị mẫu, thường được sử dụng trong các mẫu email. URL này phải là URL hoặc địa chỉ IP trỏ đến máy chủ lừa đảo Gophish và người nhận có thể truy cập được.
- Launch Date: Đây là ngày chiến dịch sẽ bắt đầu. Xem phần Lên lịch chiến dịch để biết thêm thông tin.

- **Sending Profile:** Đây là cấu hình SMTP được sử dụng khi gửi email. Cấu hình này được tạo trong phần Cấu hình gửi của tài liệu.
- **Group:** Mục này xác định những nhóm đối tượng nào nên được đưa vào chiến dịch.

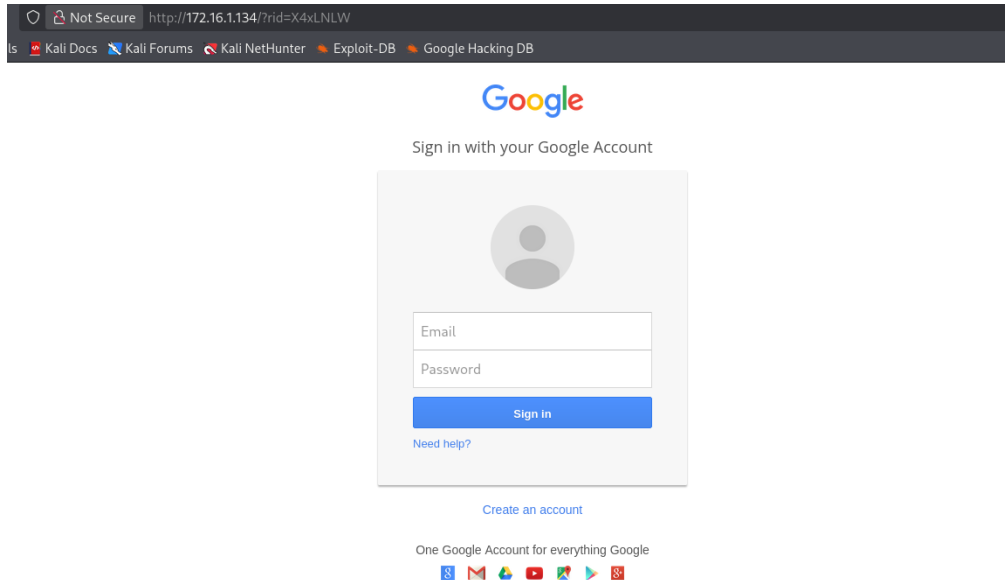
Bước 7: khởi động Campagins để gửi email phishing đến tài khoản mục tiêu



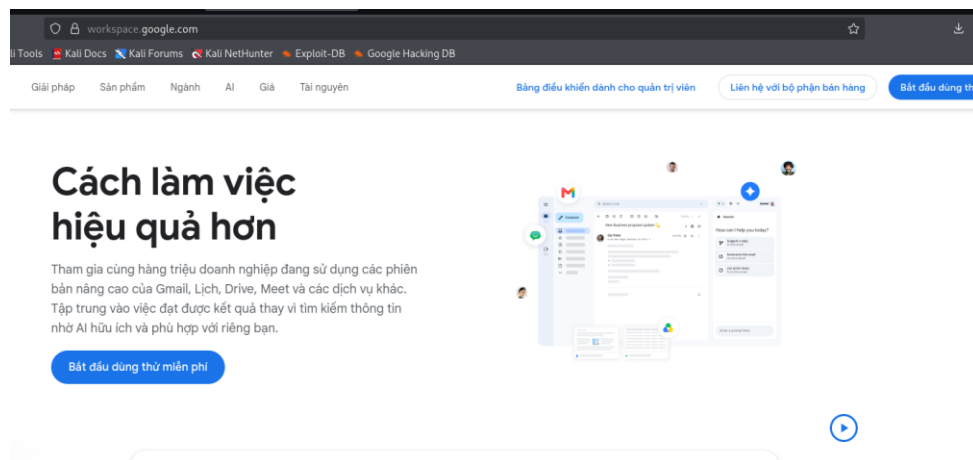
Kiểm tra máy chủ Mailcatcher để xem email đã được gửi



Giả sử người dùng click vào phần “View File” nó sẽ đưa họ đến với landing pages giả mạo phần Login của google.

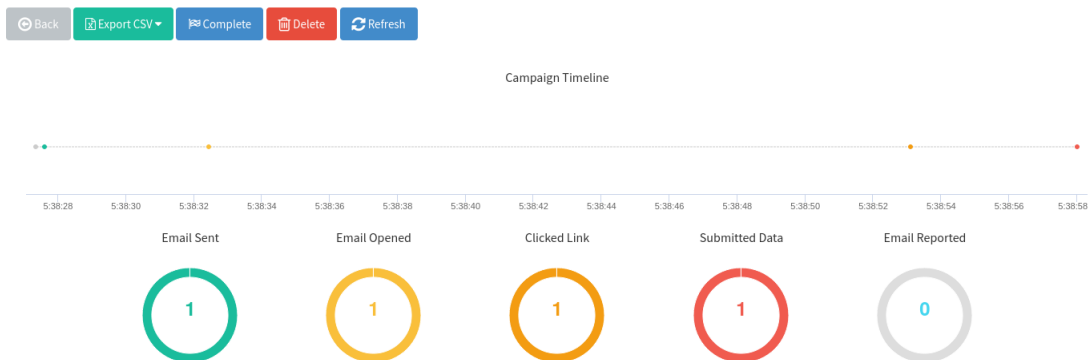


Khi người dùng nhập tài khoản và mật khẩu thì dữ liệu về tài khoản và mật khẩu của người dùng sẽ được gửi về máy chủ của GoPhish và người dùng sẽ được chuyển hướng sang 1 trang web mới



Kiểm tra dữ liệu được gửi về GoPhish

Results for phisinh

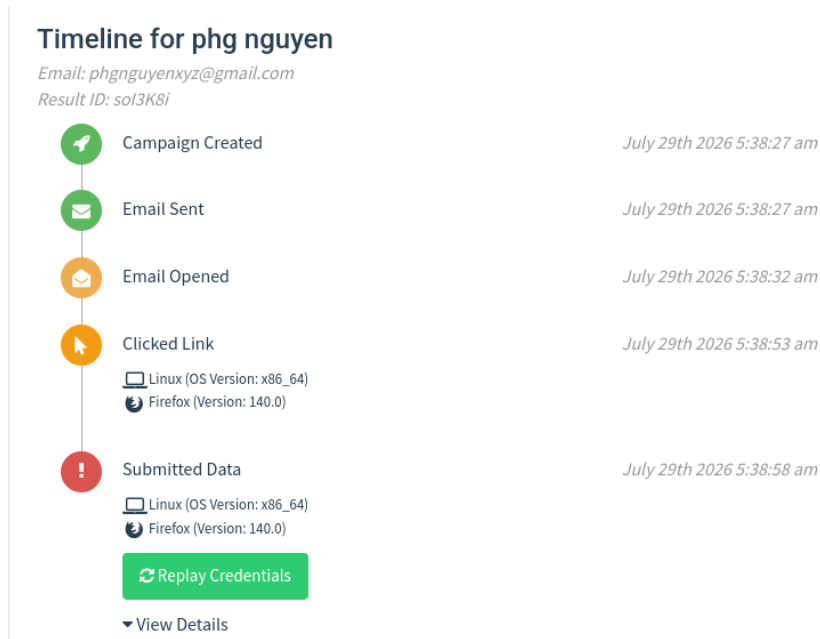


Details

Các chỉ số hành vi của người dùng được ghi lại bao gồm:

- Email Sent (Đã gửi - Màu xanh lá): 1
 - Hệ thống đã gửi thành công 1 email phishing tới mục tiêu trong chiến dịch này.
- Email Opened (Đã mở email - Màu vàng): 1
 - Nạn nhân đã mở đọc email (1 lần/người).
- Clicked Link (Đã bấm vào liên kết - Màu cam): 1
 - Nạn nhân đã sập bẫy bước đầu bằng cách bấm vào đường link độc hại có trong email (1 lần).
- Submitted Data (Đã nhập dữ liệu - Màu đỏ): 1
 - Nạn nhân tiếp tục nhập thông tin (ví dụ: điền mật khẩu hoặc tài khoản) vào trang web giả mạo do GoPhish dựng lên (1 lần). Đây là mức độ tương tác nguy hiểm nhất.
- Email Reported (Đã báo cáo email - Màu xám): 0
 - Số lượng người dùng nhận ra email bất thường và bấm nút báo cáo (Report) cho đội ngũ bảo mật/IT là Điều này cho thấy mục tiêu chưa có nhận thức phòng vệ hoặc không báo cáo sự cố.

Timeline:



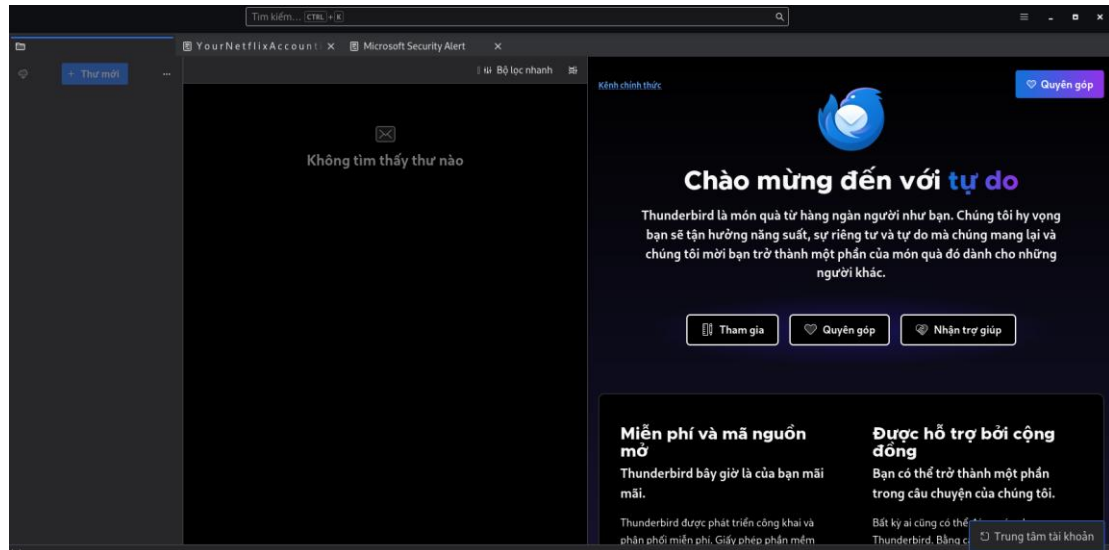
Dữ liệu mà GoPhish thu được: Quan trọng nhất là tài khoản và mật khẩu của người dùng.

Parameter	Value(s)
Email	user
GALX	SJLCKfgaqoM
PersistentCookie	yes
_utfs	0
bgresponse	js_disabled
checkConnection	
checkedDomains	youtube
continue	https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hlcDhtUFdlldzBENhIrfVWsxStdNLW9MdThibW1TMFQzVUZFc1BBaURuWmIRSQ%E2%88%99APsBz4gAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
dnConn	
dsh	-7381887106725792428
password	abcd
pstMsg	1
service	iso
signIn	Sign in

3. Quy trình điều tra số và ứng phó sự cố khi bị Phishing Attack Email.

Bước 1: Nhận diện email lừa đảo.

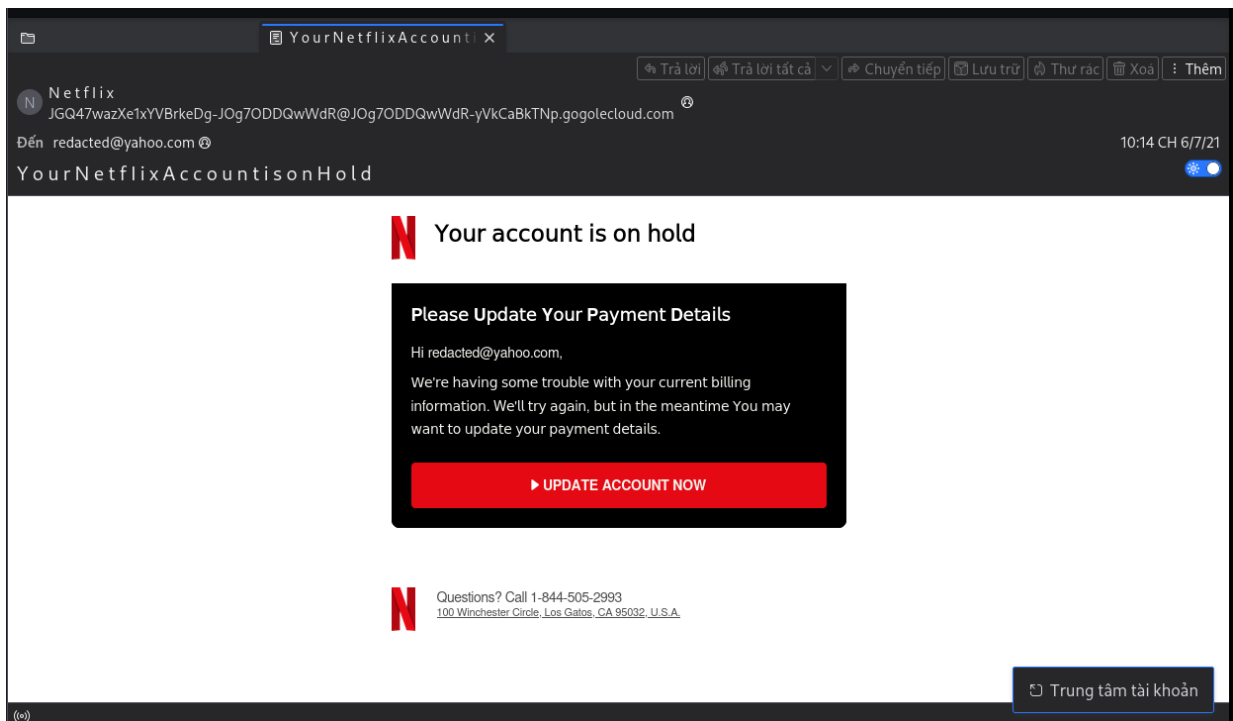
Mục tiêu : Tìm hiểu cách nhận biết email lừa đảo dựa trên các đặc điểm chung.
Thiết lập môi trường phân tích email bằng Mozilla Thunderbird.



Sử dụng công cụ thunderbird để phân tích tĩnh các email nghi vấn có chứa nội dung phishing. Vai trò của thunderbird là:

- Là môi trường Mở & Cách ly Email An toàn
- Công cụ Trích xuất Mã nguồn & Tiêu đề Raw
- Hỗ trợ Phân tích Liên kết An toàn
- Tích hợp với Công cụ Phân tích Chuyên dụng

Tải mẫu email lừa đảo vào Thunderbird để phân tích.



Qua nội dung của email ta xác định được các dấu hiệu lừa đảo trực tuyến phổ biến:

- Thông tin Người gửi (Sender Information):
 - Tên hiển thị (Display Name): Netflix Giả mạo tên hiển thị "Netflix" để đánh lừa thị giác người dùng lầm tưởng đây là thư chính hãng.
 - Địa chỉ (Email Address): ...yVkCaBkTNp.gogolecloud.com đây là một tên miền giả mạo/đạo nhái tinh vi có chủ ý, cố tình viết sai chính tả chữ Google Cloud thành gogolecloud
- Tiêu đề: Viết liền mạch không khoảng trắng (YourNetflixAccountisonHold), một thủ thuật thường thấy của kẻ tấn công nhằm né tránh các bộ lọc từ khóa tự động (Keyword Filtering) của các nhà cung cấp dịch vụ email.
- Lời chào (Greeting): Sử dụng lời chào chung chung bằng email dạng Hi redacted@yahoo.com thay vì gọi đúng tên họ đầy đủ của khách hàng.
- Nút hành động kêu gọi: Nút đỏ "UPDATE ACCOUNT NOW" dẫn tới một đường link liên kết bên ngoài (ẩn URL đích).

Bước 2: Phân tích tiêu đề email.

Thông kê kiểm tra các thông tin có trong tiêu đề của email

```
Received: from 10.197.37.234
by atlas105.free.mail.bf1.yahoo.com with HTTPS; Wed, 7 Jul 2021 02:14:46 +0000
Return-Path: <postmaster@etekno.xyz>
X-Originating-Ip: [209.85.167.226]
Received-SPF: none (domain of etekno.xyz does not designate permitted sender hosts)
Authentication-Results: atlas105.free.mail.bf1.yahoo.com;
dkim=unknown;
spf=none smtp.mailfrom=etekno.xyz;
dmarc=unknown header.from=J0g70DDQwWdR-yVkJCaBkTnp.gogolecloud.com;
X-Apparently-To: redacted@yahoo.com; Wed, 7 Jul 2021 02:14:47 +0000
X-YMailISG: soSDWIIWL DuoG8NhyrHXr7QH4K4775ng5KvMq.0Ur7XVVwU
Be3WPYvUM8wM0n0esjRJB1FL8ayJlqdiZ9E90kXzWdWdt0YQu60W8AYAEh2
wVhHZe98VYJCmHeR0pIec7.YYXLSVz9FiWUea09lCEmQ0LmI2ELSeQMPxQyi
2qZtWwPhHVUbjxbMIRQh3teEA3AlGt7wRZ_j HwdkS1nnSaFBsnrKZBFw0W1
AmDq.IFtpSufP_Qj3jDDUR3c5xSE9ZjghaA0Udfe4HQ9H_Dc47XAqD.MXAPd
Vy5UXg9I0N8lSmN4d0P72lAIQ1YkMR04c9LQ3LeP9f1sqycImfT4M_E0.Chi
AfCaG1SKxyf0GMVVjSNq..sCJS0bLHY3ZHD8.ddKlJe34v54EABsTv9q8XI
aFatYYdf0MHgWeJ3owQNYH5tT10vzXS33AXecgKPLY0XhACgm0XhNXH50t6b
YfBvWl_ViqX5nEE13Igt1KQ2Zvsih6dqNPfdK5NHx990d1z82V_Yn2scnqvE
1XnxggAq7pEEgP2N768_DQc_ES7_UpSiTTmkXHMx5T3Eib4dvDhv.YKXu71
GDJFaRc600UTtHWE44FxdVynvKHs_Z2avfKM_m2LFtlonkTeScmZRBefstPC
CkXLP0oWsXVbHbFjPEZXPu4UA9L1Cs_IlnHa7GbIcgx4.Mix2lsMTw.ihbd
68qMFXSUXQxiQU0kut7Mw5qJZvYpq85Yaoi0tYyqBIhQqATq0Mj9sfXpW5o
uRmyXBx6PHNbpwrfjnoxpr_gMKPzyS5dh07pCD1DvDwKRNbZWgCwCpSeoq.f
LUK5js1TGLW7e28G4nKHfTUl0yt4fnyM8FbEWS8hZNXBSY77wyAHhH1i5HI9
XoiPc3nb_Ma50sVUBti6MNH2ilqJehZ2AACN4zZVFbDT9hdPjqt36A2gDlu2
pAw7uhRduPd553t51qVBvKYTpCDaGzFvWIiBVXXu4v3ZYG_ykwbtsXLPZ39j
iQXKjttRPQuaLzbMXJHlenJ4Cfqt05ADm67ukSrflyPQIYpLN3a4KfYsbn33
SOMhkpr5tuQqYx0qMUKzZevD83XwhbPZ7SiQpjm7H0gva--
Received: from 209.85.167.226 (EHLO mail-oil-f226.google.com)
by 10.197.37.234 with SMTPs
(version=TLS1_2 cipher=TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256);
Wed, 07 Jul 2021 02:14:46 +0000
Received: by mail-oil-f226.google.com with SMTP id l21so1661147oig.3
for <redacted@yahoo.com>; Tue, 06 Jul 2021 19:14:46 -0700 (PDT)
```

Tiêu chí kiểm tra	Giá trị phát hiện	Đánh giá
SPF	none	Không xác định
DKIM	unknown	Không xác định
DMARC	unknown	Không xác định
Return-Path	postmaster@etekno.xyz	Không khớp với From hiển thị
Domain	...gogolecloud.com	Domain giả mạo/vô nghĩa
X-Relaying-Domain	etekno.xyz	Domain trung gian đáng ngờ
X-Mailer	Microsoft Office Outlook, Build 11.0.5510	Không khớp với hạ tầng gửi
IP nguồn gốc	180.242.199.101	Mượn hạ tầng uy tín để relay
Số lượng máy chủ trung gian (Received hops)	Nhiều bước nhảy bất thường (relay → Google → Yahoo)	Đáng ngờ

Kết luận:

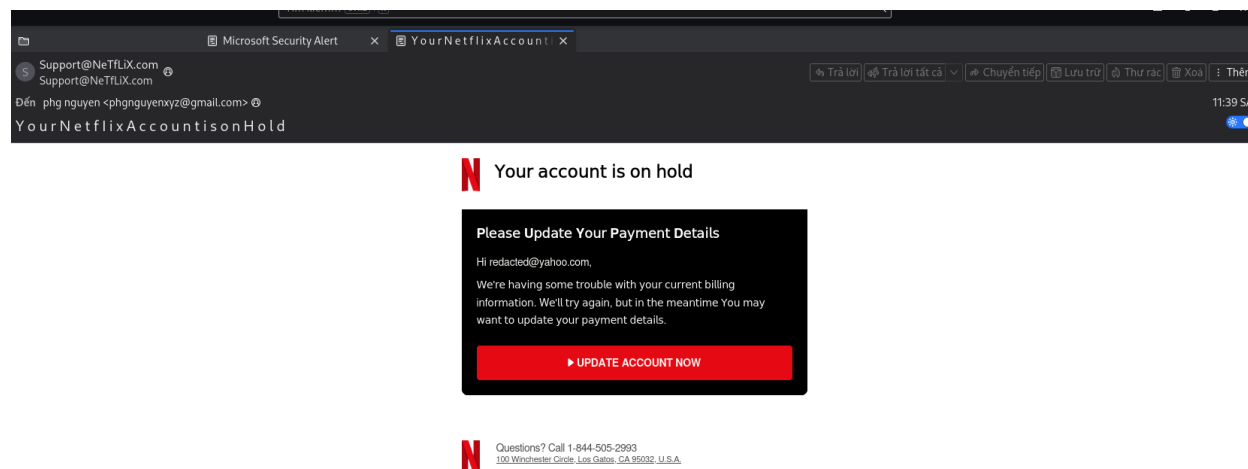
Về xác thực: Email này không vượt qua được bất kỳ cơ chế xác thực nào — cả SPF, DKIM lẫn DMARC đều ở trạng thái thất bại hoặc không xác định, cho thấy domain gửi không được ủy quyền phát tán thư dưới danh nghĩa được khai báo.

Về danh tính người gửi: Có tới 3 domain khác nhau cùng xuất hiện trong vai trò "người gửi" (etekno.xyz ở Return-Path, gogolecloud.com ở địa chỉ From thực, và thương hiệu "Netflix" bị giả mạo trong tên hiển thị)

Về nguồn gốc: Email được gửi đi từ địa chỉ IP 180.242.199.101 (khu vực Indonesia), giả danh tên host của Google, sau đó chuyển tiếp qua relay hợp lệ của Google (209.85.167.226) trước khi đến máy chủ Yahoo.

Bước 3: Điều tra Các Liên kết & Tập đính kèm.

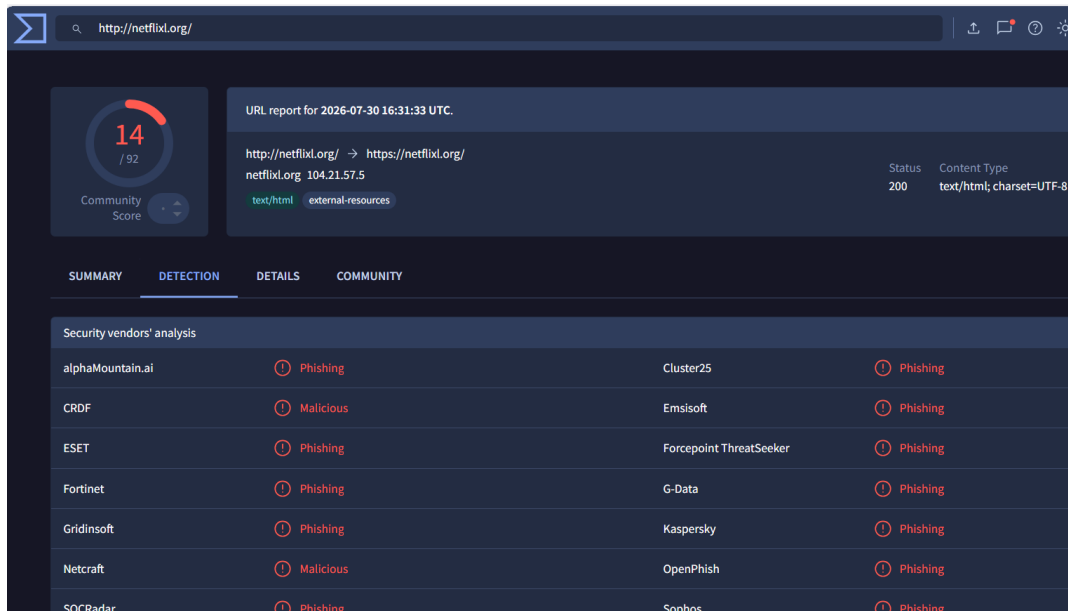
Trong nội dung Email được gửi đi có chứa đường link URL lạ đăng sau nút bấm "UPDATE ACCOUNT NOW"



Trích xuất đường link URL ra mà không cần bấm trực tiếp vào nó, nhấn chuột phải vào nút "UPDATE ACCOUNT NOW" Chọn Copy Link Location.

Đường link được trích xuất: "http://netflixl.org/"

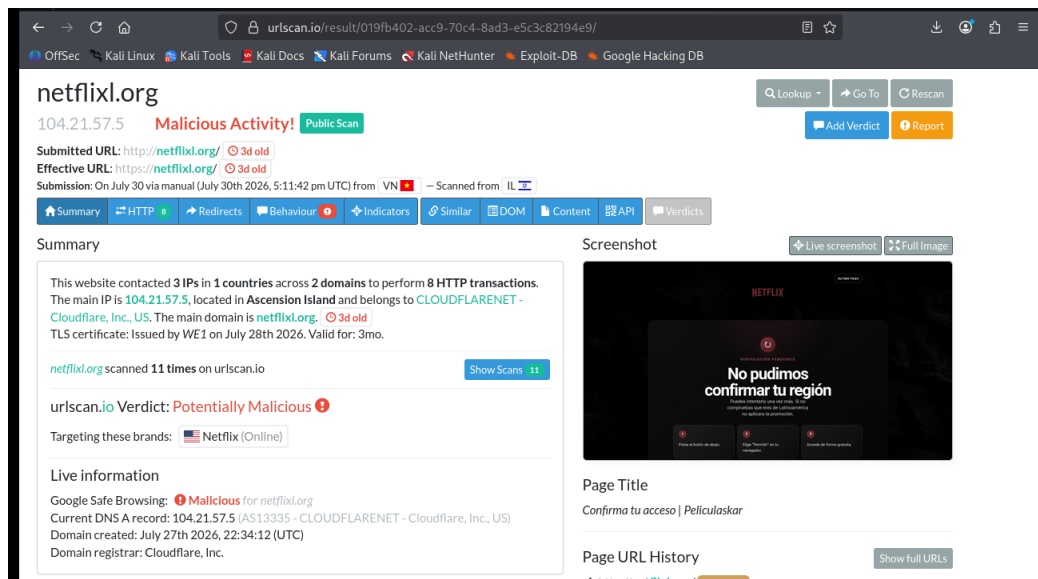
Sử dụng công cụ Virustotal để kiểm tra xem URL có nằm trong cơ sở dữ liệu cảnh báo mã độc của các hãng bảo mật hay không.



Virustotal báo có mức độ rủi ro: CAO (High) với sự đồng thuận cao từ 14 công cụ bảo mật quốc tế xác nhận đây là một trang web Lừa đảo trực tuyến (Phishing Landing Page) chuyên dùng để thu thập thông tin tài khoản và thẻ thanh toán.

Trạng thái phản hồi (Status Code): 200 (Trang web đang hoạt động bình thường và sẵn sàng phục vụ nạn nhân).

Sử dụng công cụ URLScan.io Chạy quét để hệ thống tự động chụp ảnh màn hình (Screenshot) giao diện trang web đích mà không cần trực tiếp mở trên trình duyệt cá nhân.



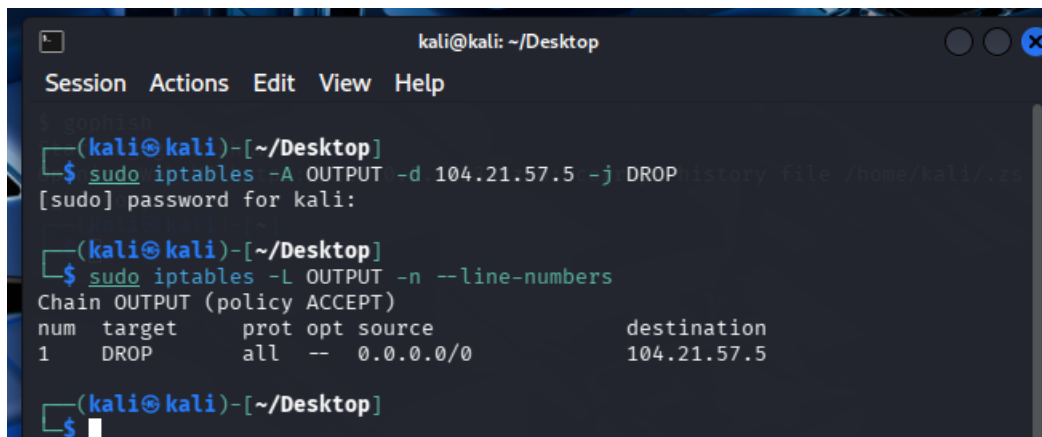
Kết luận :

- Bản chất liên kết: Sử dụng link rút gọn (t.co / bit.ly) để che giấu hạ tầng đích.
- Hạ tầng lừa đảo: Trỏ tới tên miền giả mạo http://netflixl.org/ (kỹ thuật *Typosquatting*) trên IP 104.21.57.5.
- Mức độ nguy hại: Được 14/92 hãng bảo mật (Kaspersky, ESET, Fortinet,...) xác định là Phishing.
- Đánh giá rủi ro: CAO; có nguy cơ mất cắp thông tin tài khoản và dữ liệu thanh toán nếu người dùng tương tác.

4. Ứng phó sự cố Phishing email.

Mục tiêu là chặn toàn bộ truy cập HTTP/HTTPS đến các IOC này để ngăn người dùng tiếp tục truy cập trang phishing hoặc tải mã độc.

Chặn địa chỉ IP bằng Firewall (iptables trên Kali Linux)



```
kali@kali: ~/Desktop
Session Actions Edit View Help

(kali@kali)-[~/Desktop]
$ sudo iptables -A OUTPUT -d 104.21.57.5 -j DROP
[sudo] password for kali:

(kali@kali)-[~/Desktop]
$ sudo iptables -L OUTPUT -n --line-numbers
Chain OUTPUT (policy ACCEPT)
num target prot opt source destination
1 DROP all -- 0.0.0.0/0 104.21.57.5

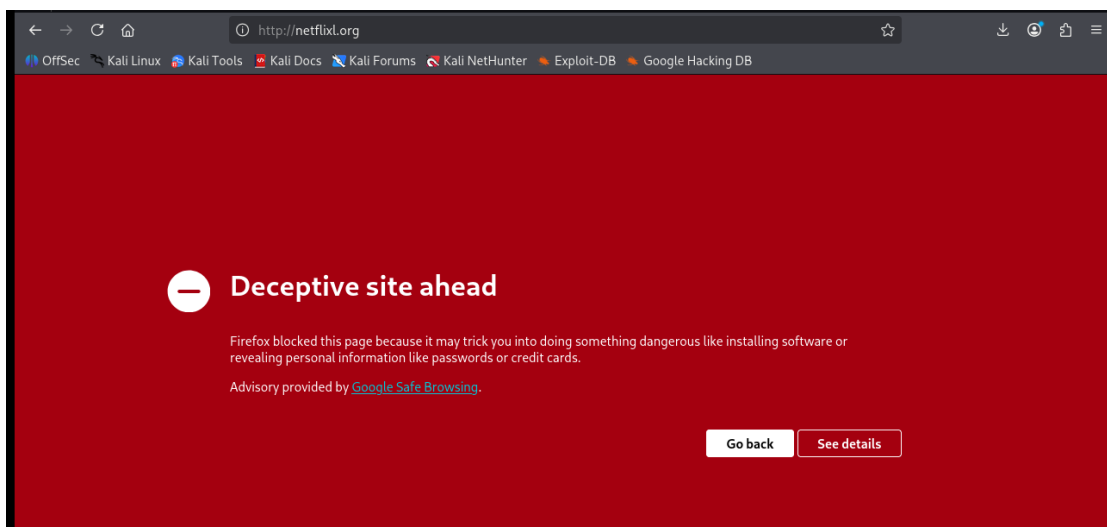
(kali@kali)-[~/Desktop]
$
```

Chặn theo tên miền cấu hình file /etc/hosts để chuyển hướng tên miền về localhost.


```
kali@kali: ~/Desktop
Session Actions Edit View Help
GNU nano 8.6 /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
127.0.0.1 netflixl.org
127.0.0.1 www.netflixl.org
127.0.0.1 bit.ly
127.0.0.1 t.co
```

Kết quả: khi ping tới địa chỉ web và truy cập bằng link URL.

```
(kali@kali)-[~/Desktop]
$ ping netflixl.org
PING netflixl.org (127.0.0.1) 56(84) bytes of data.
64 bytes from localhost (127.0.0.1): icmp_seq=1 ttl=64 time=0.097 ms
64 bytes from localhost (127.0.0.1): icmp_seq=2 ttl=64 time=0.031 ms
64 bytes from localhost (127.0.0.1): icmp_seq=3 ttl=64 time=0.046 ms
64 bytes from localhost (127.0.0.1): icmp_seq=4 ttl=64 time=0.031 ms
^C
```



Triệt tiêu & Xử lý : Quét và xóa triệt để email giả mạo khỏi hòm thư của toàn bộ người dùng trong hệ thống; vô hiệu hóa các phiên đăng nhập (Revoke Sessions) nếu phát hiện nạn nhân đã nhấp vào liên kết.

Khôi phục & Giám sát (Recovery & Monitoring): Yêu cầu người dùng nghi vấn đổi mật khẩu khẩn cấp, kích hoạt xác thực đa yếu tố (MFA) và theo dõi sát sao logs hệ thống trong 48 giờ tiếp theo.